

Security+ 4.3 · Analyzing Vulnerabilities

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.3** —
Analyzing Vulnerabilities (10:29) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: CVSS scores range from 0 to 10: low (0.1-3.9), medium (4.0-6.9), high (7.0-8.9), critical (9.0-10.0). CVE provides a global catalog of vulnerabilities. Prioritization combines CVSS score with exposure: internet-facing critical vulnerabilities require immediate remediation.

High-Yield Core Concepts Tested on Exam

- CVSS 9.0+ = Critical; 7.0-8.9 = High; 4.0-6.9 = Medium; 0.1-3.9 = Low
- CVE is the global catalog of known vulnerabilities
- Prioritization = CVSS score + exposure (internet-facing first)
- Critical vulnerability on internet-facing server = patch immediately
- CVSS provides standardized severity rating but context matters

Exam Tips & Classic Scenarios

- 'CVSS score of 9.8' = Critical
- 'CVSS score of 7.5' = High
- 'internet-facing critical vulnerability' = highest priority

Typical Exam Scenario: A vulnerability with CVSS 9.8 on an internet-facing server is rated critical and must be patched immediately.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.3 — Analyzing Vulnerabilities)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **CVE:** Common Vulnerabilities and Exposures: Publicly standardized dictionary of known information security vulnerabilities and exposures.
- **CVSS:** Common Vulnerability Scoring System: Industry standardized 0.0 to 10.0 framework evaluating vulnerability severity (Low, Medium, High, Critical).

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. In the CVSS 3.1 system, a vulnerability with a score of 9.8 is classified as:

- A)** Low
- B)** Medium
- C)** High
- D)** Critical

2. A CVE-2024-1234 vulnerability scored CVSS 3.1 as 7.5 (High). What should be done FIRST?

- A)** Apply patch immediately on all servers
- B)** Assess the risk in the context of the specific environment
- C)** Ignore it because it is not critical
- D)** Replace the affected system

3. Which metric defines the maximum acceptable data loss time in a Disaster Recovery plan, measuring the interval between backups or replicas?

- A)** RTO (Recovery Time Objective)
- B)** RPO (Recovery Point Objective)
- C)** MTTR (Mean Time to Repair)
- D)** SLI (Service Level Indicator)

4. Corporate scenario (Analyzing Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 4.3) exam, an analyst evaluates the following technical requirement: 'CVSS 9+ = critical; 7+ = high'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: CVSS 9+ = critical; 7+ = high.
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Analyzing Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'Priority = CVSS + EXPOSURE (internet-facing first)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Priority = CVSS + EXPOSURE (internet-facing first)...

6. Corporate scenario (Analyzing Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: "CVSS score of 9.8'=Critical'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'CVSS score of 9.8'=Critical...

7. Corporate scenario (Analyzing Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'vulnerability with CVSS 9.8 on the internet server' = critical — patch today. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'vulnerability with CVSS 9.8 on the internet server' = critical — patch today....
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Analyzing Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'CVSS 9+ = critical; 7+ = high'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: CVSS 9+ = critical; 7+ = high...

9. Corporate scenario (Analyzing Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'Priority = CVSS + EXPOSURE (internet-facing first)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Priority = CVSS + EXPOSURE (internet-facing first)...

10. Corporate scenario (Analyzing Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'CVSS score of 9.8' = Critical. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'CVSS score of 9.8' = Critical...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) D — Critical.

✓ **Why it's correct:** In the CVSS 3.1 (Common Vulnerability Scoring System), the base score ranges from 0.0 to 10.0 and is categorized into four ranges: Low (0.1–3.9), Medium (4.0–6.9), High (7.0–8.9), and Critical (9.0–10.0). A vulnerability with a score of 9.8 therefore falls into the Critical range, indicating severe impact and trivial or near-trivial exploitability, with the potential to compromise confidentiality, integrity, and availability massively. CompTIA Security+ requires professionals to interpret these ranges to prioritize remediation.

✗ **Why the others are wrong:**

- *Low:* The Low classification in CVSS 3.1 covers scores from 0.1 to 3.9. Vulnerabilities in this range typically require very specific conditions for exploitation, have limited impact, or require highly privileged local access. A score of 9.8 is far above this range, indicating extreme, non-trivial risk. Associating 9.8 with Low demonstrates a complete misunderstanding of the scale.
- *Medium:* The Medium range in CVSS 3.1 goes from 4.0 to 6.9. Medium vulnerabilities can cause moderate damage, often requiring user interaction or partial exploitation conditions. A score of 9.8 far exceeds this threshold, placing it at the top of the scale. Classifying it as Medium would severely underestimate the urgency of remediation and contradict the standard's own numerical definition.
- *High:* The High range in CVSS 3.1 comprises scores from 7.0 to 8.9. Although it is a serious classification, it is still below the Critical threshold. A 9.8 vulnerability is considered Critical because it typically combines remote attack vectors, low complexity, no required privileges, and high impact on all three security pillars. Therefore, labeling it as High is technically incorrect according to the official CVSS 3.1 specification.

2) B — Assess the risk in the context of the specific environment.

✓ **Why it is correct:** Faced with a vulnerability scoring CVSS 7.5 (High), the first action according to vulnerability management best practices and the CompTIA Security+ syllabus is to assess the risk in the specific context of the environment. This means considering the criticality of the affected asset, network exposure, existence of compensating controls, likelihood of real exploitation (e.g., if there is a public exploit or threat activity), and business impact. Only after this contextual analysis is the priority and remediation strategy decided, which may include immediate patching, temporary mitigation, or risk acceptance. The CVSS score is a generic metric and does not replace organizational risk assessment.

✗ **Why the others are wrong:**

- *Apply patch immediately on all servers:* Applying patches immediately on all servers without prior assessment is a reckless approach. Patches can introduce regressions, incompatibilities, or downtime for critical services, and require maintenance windows and testing. Change management and contextual risk assessment are mandatory before any large-scale deployment. Haste can cause more damage than the vulnerability itself, especially if the asset is not exposed or if effective mitigations exist.
- *Ignore it because it is not critical:* Ignoring a vulnerability scoring 7.5 (High) because it is not Critical is a serious prioritization error. The High range indicates significant risk, with potential to seriously compromise the environment. Even if not 9.0+, a High vulnerability can be exploited by attackers to gain initial access, escalate privileges, or cause denial of service. The decision not to act must be based on documented risk analysis, not on a simplistic classification that dismisses everything below Critical.
- *Replace the affected system:* Replacing the affected system is an extreme, costly, and often

infeasible measure in the short term. System replacement involves planning, budgeting, data migration, and testing, and is not an immediate response to a vulnerability. Moreover, the vulnerability can be fixed with a patch or mitigation, making replacement unnecessary. The first action should always be contextual assessment to then decide the proportional response, which is rarely a complete system swap.

3) B — RPO (Recovery Point Objective).

✓ **Why it's correct:** The correct option is 'RPO (Recovery Point Objective)'. According to the official CompTIA Security+ (SY0-701) syllabus, RPO is the metric that defines the maximum amount of data that can be lost in the event of a disruption, measured in time. It represents the maximum acceptable interval between the last backup or replica and the moment of failure. For example, if the RPO is 4 hours, it means that in a disaster, up to 4 hours of data can be lost, because the last valid recovery point is up to 4 hours old. RPO guides backup frequency: the lower the RPO, the more frequent the copies must be. It is a fundamental metric in Disaster Recovery (DR) and Business Continuity (BCP) plans, as it quantifies the organization's tolerance for data loss.

✗ **Why the others are wrong:**

- *RTO (Recovery Time Objective)*: RTO (Recovery Time Objective) is the maximum acceptable time to restore a service or system after a disruption. It measures how long the organization can go without the service, not the amount of data lost. In a DR plan, RTO defines the recovery window: for example, if the RTO is 2 hours, the service must be restored within 2 hours. RTO is related to availability and continuity, while RPO is related to integrity and data loss. This option is wrong because the question asks about data loss (interval between backups), not about service restoration time.
- *MTTR (Mean Time to Repair)*: MTTR (Mean Time to Repair) is a maintenance metric that represents the average time required to repair a component or system after a failure. It is used in incident management and reliability, but it does not define the maximum acceptable data loss. MTTR focuses on repair time, not on the data recovery point. In security, MTTR can be used to measure incident response efficiency, but it does not replace RPO in a DR plan. This option is wrong because it does not address data loss, but rather average repair time.
- *SLI (Service Level Indicator)*: SLI (Service Level Indicator) is a quantitative metric that measures an aspect of service level, such as latency, error rate, or throughput. It is used in SRE (Site Reliability Engineering) to monitor service health and define SLOs (Service Level Objectives). SLI does not define the maximum acceptable data loss; it measures the current performance of the service. In a DR plan, SLI can be used to monitor recovery, but it is not the metric that establishes the interval between backups. This option is wrong because it does not refer to data loss, but rather to service level indicators.

4) B — Implement the corresponding solution: CVSS 9+ = critical; 7+ = high..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Analyzing Vulnerabilities): CVSS 9+ = critical; 7+ = high. The Common Vulnerability Scoring System (CVSS) provides a numerical score to assess severity, with 9.0-10.0 as critical and 7.0-8.9 as high, guiding prioritization of remediation efforts.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.

- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: Priority = CVSS + EXPOSURE (internet-facing first)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Analyzing Vulnerabilities): Priority = CVSS + EXPOSURE (internet-facing first). CVSS provides a standardized severity score, but exposure determines actual risk. Internet-facing systems are more likely to be targeted and exploited, so they should be prioritized for remediation. This aligns with risk-based vulnerability management.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: 'CVSS score of 9.8'=Critical....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Analyzing Vulnerabilities): 'CVSS score of 9.8'=Critical. The Common Vulnerability Scoring System (CVSS) provides a numerical score from 0.0 to 10.0 reflecting severity; scores from 9.0 to 10.0 are classified as Critical, indicating vulnerabilities that are easily exploitable and have severe impact, requiring immediate remediation.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: 'vulnerability with CVSS 9.8 on the internet server' = critical — patch today.....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Analyzing Vulnerabilities): 'vulnerability with CVSS 9.8 on the internet server' = critical — patch today.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

8) D — Implement the corresponding solution: CVSS 9+ = critical; 7+ = high....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Analyzing Vulnerabilities): CVSS 9+ = critical; 7+ = high. This reflects the standard CVSS severity ratings used to prioritize vulnerability remediation.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: Priority = CVSS + EXPOSURE (internet-facing first)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Analyzing Vulnerabilities): Priority = CVSS + EXPOSURE (internet-facing first). CVSS provides the severity score, but prioritization must also factor in exposure—internet-facing systems are at higher risk and should be remediated first.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: 'CVSS score of 9.8' = Critical....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Analyzing Vulnerabilities): 'CVSS score of 9.8' = Critical. The Common Vulnerability Scoring System (CVSS) rates vulnerabilities from 0.0 to 10.0, with 9.0–10.0 classified as Critical. A score of 9.8 indicates a vulnerability that is easily exploitable, requires no special privileges, and can lead to complete system compromise, thus demanding immediate remediation.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.